Pruebas de seguridad y mitigación de riesgos

Breve descripción:

Este componente desarrolla habilidades para ejecutar acciones preventivas, monitorear infraestructuras y validar vulnerabilidades, amenazas y riesgos mediante herramientas tecnológicas de seguridad. Además, orienta la aplicación responsable de controles, el análisis de ataques, la protección de aplicaciones web, servicios en la nube y dispositivos conectados, y la documentación técnica de incidentes.

Octubre 2026

Tabla de contenido

Introducción 4

1. Desarrollo seguro y protección de aplicaciones 7

1.1 Código seguro y prevención de vulnerabilidades 7

1.2 Aplicaciones web, servicios en la nube y criterios de seguridad 10

1.3 Análisis de código, monitoreo y registro de hallazgos 12

2. Dispositivos conectados e infraestructuras críticas 16

2.1 Internet de las cosas y exposición de dispositivos conectados 16

2.2 Vulnerabilidades en dispositivos conectados 18

2.3 Infraestructuras críticas y procedimientos de mitigación 21

3. Ataques, cibercrimen y amenazas dirigidas 24

3.1 Taxonomía y clasificación general de ataques 24

3.2 Cibercrimen y evolución de las amenazas digitales 27

3.3. Amenazas cibernéticas dirigidas a personas 29

4. Internet seguro y clasificación de entornos web 32

4.1 Clean web, deep web y dark web 32

4.2 Búsquedas seguras y criterios de consulta 34

4.3 Buscadores especializados y criterios de seguridad 35

5. Monitoreo, mitigación y validación de riesgos 37

5.1 Métodos y técnicas de monitoreo 37

5.2 Herramientas tecnológicas de seguridad 39

5.3 Mitigación de riesgos y verificación de resultados 41

Síntesis 47

Glosario 48

Referencias bibliográficas 49

Créditos 51

Introducción

La protección de la información y de los servicios digitales requiere avanzar desde la identificación inicial de vulnerabilidades hacia la ejecución de acciones preventivas y la validación de resultados. Un diagnóstico permite reconocer debilidades, amenazas y riesgos; sin embargo, su valor se concreta cuando la organización selecciona herramientas apropiadas, monitorea su infraestructura, aplica controles y verifica si las medidas implementadas reducen efectivamente la exposición. La ciberseguridad debe entenderse, por tanto, como un proceso continuo de seguimiento, decisión, actuación y mejora.

En el componente Pruebas de seguridad y mitigación de riesgos, el aprendiz analizará situaciones aplicadas a infraestructuras tecnológicas, aplicaciones web, servicios alojados en la nube, dispositivos conectados y fuentes masivas de datos. Esta diversidad responde a una realidad organizacional: los sistemas ya no se encuentran necesariamente concentrados en un único lugar. Una institución educativa puede gestionar plataformas virtuales, sitios web, repositorios colaborativos, redes inalámbricas, cámaras conectadas y bases de datos con información académica. Una unidad productiva puede utilizar sistemas de facturación, servicios cloud, formularios web y dispositivos de monitoreo. Cada elemento aporta valor, pero también introduce condiciones de seguridad que deben revisarse.

El desarrollo temático mantiene una progresión pedagógica. En primer lugar, se explica la transición entre exploración, prevención y validación. Posteriormente, se profundiza en código seguro, aplicaciones web y sistemas en la nube. En los siguientes apartados se abordarán internet de las cosas, monitoreo de infraestructura, taxonomía

de ataques, cibercrimen, amenazas dirigidas a personas, infraestructuras críticas e internet seguro.

El componente también fortalece una postura ética. Las pruebas de seguridad, el monitoreo y la validación deben realizarse únicamente sobre sistemas autorizados o entornos de laboratorio. El conocimiento adquirido se orienta a proteger activos, reducir riesgos y mejorar procesos. La formación profesional integral exige utilizar la tecnología con responsabilidad, respetar la privacidad de las personas y comunicar los hallazgos mediante canales adecuados.

Video 1. Pruebas de seguridad y mitigación de riesgos



Enlace de reproducción del video

Transcripción del video: pruebas de seguridad y mitigación de riesgos
La transformación digital ha ampliado el uso de plataformas institucionales, servicios en la nube, aplicaciones web, redes y dispositivos conectados. Esta realidad exige comprender la ciberseguridad como una práctica continua para prevenir

Transcripción del video: pruebas de seguridad y mitigación de riesgos
afectaciones, proteger información y asegurar la continuidad de servicios educativos, productivos y comunitarios. Para el aprendiz, este componente resulta relevante porque fortalece capacidades aplicables en entornos laborales donde se administran sistemas, cuentas, datos y servicios digitales. El dominio de acciones preventivas, monitoreo y validación de resultados favorece la empleabilidad, la confianza digital y la protección responsable de activos tecnológicos. En este componente formativo se estudiarán el código seguro, la protección de aplicaciones web y servicios cloud, la exposición de dispositivos IOT, las infraestructuras críticas, la clasificación de ataques, el cibercrimen, las amenazas dirigidas a personas, los entornos web seguros, las herramientas de seguridad y la mitigación de riesgos. Estos contenidos se articulan con la ejecución de acciones preventivas y la validación de vulnerabilidades, amenazas y riesgos mediante herramientas tecnológicas de seguridad. Al finalizar, el aprendiz contará con criterios técnicos y éticos para aplicar controles, revisar evidencias, documentar hallazgos y verificar si las medidas reducen la exposición sin afectar la operación legítima. Este aprendizaje contribuye a proteger personas, información, servicios digitales e infraestructuras críticas en las organizaciones y territorios.

1. Desarrollo seguro y protección de aplicaciones

El desarrollo seguro y la protección de aplicaciones integran prácticas preventivas orientadas a reducir vulnerabilidades antes de que los servicios lleguen a producción. Este tema aborda la importancia del código seguro, la protección de aplicaciones web y servicios en la nube, el análisis de código, el monitoreo y el registro de hallazgos como acciones necesarias para fortalecer la seguridad de la información.

1.1 Código seguro y prevención de vulnerabilidades

La seguridad de una aplicación no debería incorporarse únicamente al final del desarrollo. Cuando las prácticas preventivas se integran desde el diseño, resulta posible reducir vulnerabilidades antes de que lleguen a producción. El concepto de código seguro no significa que un programa pueda considerarse completamente libre de riesgos. Significa que el desarrollo adopta criterios para prevenir debilidades, detectar errores y responder oportunamente ante hallazgos.

NIST publicó el Secure Software Development Framework (SSDF) versión 1.1 como un conjunto de prácticas de alto nivel orientadas a reducir el riesgo de vulnerabilidades de software. El marco busca integrarse a los ciclos de desarrollo existentes, debido a que muchos modelos tradicionales no abordan la seguridad con suficiente detalle (NIST, 2022).

El código seguro corresponde al software desarrollado mediante prácticas que reducen la posibilidad de errores aprovechables, protegen los datos y facilitan la detección de comportamientos no esperados. Su calidad no depende únicamente de que la aplicación cumpla una función. También debe analizarse cómo procesa entradas, administra sesiones, controla permisos, registra eventos y maneja errores.

Una aplicación puede funcionar correctamente para un usuario legítimo y, al mismo tiempo, presentar vulnerabilidades. Por ejemplo, un formulario de contacto puede almacenar mensajes sin validar adecuadamente los datos ingresados. Una página administrativa puede mostrar información sensible a usuarios sin los permisos apropiados. Un sistema puede presentar mensajes de error que revelan detalles internos. Estas situaciones demuestran que funcionalidad y seguridad son dimensiones relacionadas, pero diferentes.

El código seguro se caracteriza por adoptar controles proporcionales al riesgo. La aplicación debe validar datos, administrar errores de forma adecuada, proteger credenciales, aplicar controles de acceso y registrar actividades relevantes. También debe utilizar componentes confiables y mantenerse actualizada. El objetivo no consiste en agregar barreras innecesarias, sino en proteger el servicio y a sus usuarios.

La prevención de vulnerabilidades requiere integrar la seguridad en las diferentes etapas del ciclo de desarrollo. Para facilitar su comprensión, el siguiente recurso presenta los momentos principales en los que pueden incorporarse acciones preventivas.

- **Seguridad durante el ciclo de desarrollo**
  - **Planeación:** se identifican requisitos y riesgos antes de iniciar el desarrollo de la aplicación.
  - **Diseño:** se definen controles, flujos y criterios de seguridad acordes con el servicio.
  - **Construcción:** se aplican prácticas de codificación segura y control de dependencias.
  - **Pruebas:** se verifican comportamientos, entradas, permisos y posibles errores.

- **Despliegue y operación:** se revisan configuraciones, se monitorean eventos y se gestionan actualizaciones.

El SSDF de NIST agrupa prácticas de desarrollo seguro para facilitar su incorporación a distintos ciclos de vida. Su utilidad pedagógica consiste en demostrar que la seguridad no corresponde a una actividad aislada. Una vulnerabilidad detectada en producción puede tener origen en una decisión temprana: una dependencia no verificada, un requisito incompleto o una configuración predeterminada insegura (NIST, 2022).

Entre las buenas prácticas se encuentra la validación de entradas. Una aplicación no debe asumir que todo dato recibido es confiable. También resulta importante controlar permisos, evitar la exposición de secretos en el código fuente, gestionar dependencias, revisar cambios y mantener trazabilidad. Cada práctica responde a una pregunta concreta: ¿qué podría ocurrir si el sistema recibe datos inesperados, si un usuario intenta acceder a una función restringida o si un componente deja de recibir actualizaciones?

OWASP Application Security Verification Standard (ASVS) versión 5.0 ofrece requisitos verificables para diseñar, desarrollar y evaluar aplicaciones web y servicios modernos. El estándar facilita establecer criterios de seguridad y niveles de rigor según el contexto de la aplicación (OWASP Foundation, 2025). Su aporte no consiste en reemplazar el análisis, sino en aportar una referencia estructurada.

1.2 Aplicaciones web, servicios en la nube y criterios de seguridad

Una Las aplicaciones web y los sistemas en la nube forman parte de la operación cotidiana de organizaciones educativas, empresas y emprendimientos. Permiten publicar información, recibir solicitudes, almacenar documentos, administrar procesos y ofrecer servicios a usuarios ubicados en distintos lugares. Esta flexibilidad también amplía la superficie de exposición y exige aplicar criterios de seguridad.

La prevención comienza por comprender la arquitectura. Un sitio web no está compuesto únicamente por páginas visibles. Puede incluir servidor, base de datos, formularios, API, sistema de autenticación, cuentas administrativas, componentes de terceros y servicios cloud. Cada elemento requiere controles y monitoreo.

Una aplicación web es un sistema al que se accede mediante navegador u otro cliente conectado a una red. Puede cumplir funciones informativas, transaccionales o colaborativas. Un portal institucional publica contenidos; una plataforma de matrícula procesa registros; un sistema de comercio electrónico administra pedidos; y un aula virtual facilita interacción formativa.

Las aplicaciones web operan mediante intercambio de solicitudes y respuestas. El usuario envía datos; el sistema procesa la información; y el servidor entrega un resultado. Esta interacción parece sencilla, pero involucra múltiples componentes. Una falla en cualquiera de ellos puede afectar la seguridad.

En una institución educativa, un formulario de inscripción puede recopilar nombre, identificación, correo y programa de interés. La organización debe preguntarse qué datos son necesarios, quién puede consultarlos y cómo se protegen. La seguridad web no se limita a impedir ataques; también implica tratar la información de manera responsable.

La seguridad requiere aplicar criterios coherentes con el servicio. El siguiente recurso organiza los principales criterios que deben considerarse para proteger aplicaciones web y servicios en la nube.

- **Criterios de seguridad en aplicaciones web**
  - **Gestión de identidades:** permite limitar permisos y controlar el acceso a funciones sensibles.
  - **Configuración segura:** reduce condiciones de exposición generadas por ajustes predeterminados o innecesarios.
  - **Actualización de componentes:** disminuye riesgos asociados con vulnerabilidades divulgadas.
  - **Protección de la información:** orienta el cuidado de los datos durante su transmisión y almacenamiento.
  - **Registros y copias de respaldo:** facilita la revisión de eventos y la recuperación ante una afectación.

La autenticación multifactor aporta una capa adicional, especialmente para cuentas administrativas. El privilegio mínimo limita el alcance de una cuenta comprometida. La segmentación reduce la propagación. El monitoreo facilita detectar cambios. La gestión de actualizaciones disminuye exposición a vulnerabilidades divulgadas.

El análisis debe considerar la experiencia del usuario. Un control que impide realizar tareas legítimas puede generar prácticas alternativas inseguras. Por ello, la seguridad necesita equilibrio entre protección y usabilidad. La organización debe diseñar procedimientos claros y acompañar a los usuarios.

1.3 Análisis de código, monitoreo y registro de hallazgos

El análisis de código permite identificar debilidades antes o durante el despliegue. Puede desarrollarse mediante revisión manual, análisis automatizado y evaluación de componentes. Cada técnica aporta información diferente.

La revisión manual ayuda a comprender decisiones lógicas, flujos de datos y controles de acceso. Su valor reside en la interpretación contextual. El análisis automatizado puede detectar patrones inseguros, errores frecuentes o dependencias vulnerables. Sin embargo, sus resultados requieren validación. Una herramienta puede generar falsos positivos o no comprender completamente la lógica del negocio.

El análisis estático examina el código sin ejecutar la aplicación. Puede identificar prácticas inseguras, secretos expuestos o patrones de error. El análisis dinámico revisa el comportamiento durante la ejecución. Permite analizar cómo responde la aplicación frente a solicitudes, sesiones o entradas. El análisis de composición de software se concentra en bibliotecas y dependencias incorporadas al proyecto. Esta revisión resulta relevante porque una aplicación puede utilizar componentes desarrollados por terceros.

La revisión de código y las pruebas de seguridad deben generar documentación útil. Un hallazgo debe incluir el componente afectado, la descripción de la debilidad, la evidencia, el impacto potencial, la prioridad y la recomendación. Esta estructura evita expresiones genéricas como “la aplicación es insegura”.

Las prácticas de desarrollo seguro deben relacionarse con acciones preventivas y evidencias verificables. Para presentar esta relación de forma más clara, la información se organiza en una infografía de ventanas modales.

- **Prácticas de desarrollo seguro y acciones preventivas**
  - **Validar datos de entrada**
    - **Finalidad:** evitar que la aplicación procese información inesperada o manipulada.
    - **Ejemplo aplicado:** revisar los campos de un formulario web.
    - **Evidencia para validar:** resultado de pruebas con datos válidos y no válidos.
  - **Aplicar control de acceso**
    - **Finalidad:** restringir funciones según el rol del usuario.
    - **Ejemplo aplicado:** impedir que un usuario básico consulte el panel administrativo.
    - **Evidencia para validar:** registro de permisos y resultado de pruebas por perfil.
  - **Gestionar dependencias**
    - **Finalidad:** reducir riesgos asociados con componentes desactualizados.
    - **Ejemplo aplicado:** verificar bibliotecas utilizadas por un sitio web.
    - **Evidencia para validar:** inventario de versiones y contraste con fuentes técnicas.
  - **Manejar errores de forma segura**
    - **Finalidad:** evitar la exposición de detalles internos.
    - **Ejemplo aplicado:** configurar mensajes comprensibles sin revelar información sensible.
    - **Evidencia para validar:** capturas anonimizadas y revisión de registros.

- **Registrar eventos relevantes**
  - **Finalidad:** facilitar monitoreo, validación y respuesta.
  - **Ejemplo aplicado:** conservar trazabilidad de accesos fallidos y cambios administrativos.
  - **Evidencia para validar:** registros con fecha, tipo de evento y actor relacionado.

La documentación de hallazgos permite que las acciones preventivas no queden como actividades aisladas. Cuando se conserva evidencia, se facilita la validación posterior y se mejora la toma de decisiones frente a nuevas revisiones de seguridad.

El monitoreo permite identificar eventos, cambios y comportamientos relevantes. Puede incluir registros de acceso, alertas, consumo de recursos, modificaciones administrativas y eventos de seguridad. La finalidad no consiste en acumular datos sin criterio, sino en obtener visibilidad útil.

Una metodología básica establece qué se debe monitorear, con qué frecuencia, quién revisa las alertas y cómo se documentan los resultados. La ausencia de responsables convierte el monitoreo en una actividad incompleta. Una alerta no gestionada aporta poca protección.

Las herramientas dependen del entorno. Un servidor puede generar registros de accesos y errores. Una plataforma cloud puede ofrecer paneles de actividad. Una aplicación web puede conservar eventos de autenticación. Un sistema de protección puede detectar comportamientos anómalos. La selección debe responder al riesgo y a la capacidad institucional.

En formación virtual, un laboratorio puede incluir registros simulados. El aprendiz identifica intentos fallidos, cambios de permisos y accesos inusuales. Posteriormente,

clasifica los eventos y determina cuáles requieren revisión. Esta práctica desarrolla capacidad analítica sin afectar sistemas reales.

2. Dispositivos conectados e infraestructuras críticas

Los dispositivos conectados y las infraestructuras críticas forman parte de los entornos tecnológicos que requieren acciones preventivas, monitoreo y validación permanente. En este tema se abordan los elementos del internet de las cosas, las vulnerabilidades frecuentes en dispositivos conectados y los procedimientos de mitigación aplicables a servicios o sistemas cuya afectación puede generar impactos significativos.

2.1 Internet de las cosas y exposición de dispositivos conectados

La transformación digital ha ampliado el número de dispositivos que participan en los procesos organizacionales. Ya no se utilizan únicamente computadores, servidores y teléfonos móviles. En contextos productivos, educativos y administrativos pueden encontrarse sensores de temperatura, cámaras, sistemas de control de acceso, impresoras conectadas, equipos de medición, dispositivos para seguimiento de inventarios y componentes de automatización. Estos elementos forman parte del internet de las cosas y requieren medidas de seguridad acordes con su función.

La incorporación de dispositivos conectados aporta beneficios importantes. Un sensor puede advertir cambios ambientales en una unidad productiva; una cámara puede apoyar la vigilancia de instalaciones; y un sistema de control de acceso puede contribuir a registrar ingresos. Sin embargo, cada dispositivo también amplía la superficie de exposición. Si conserva credenciales predeterminadas, utiliza software desactualizado o se conecta a una red sin segmentación, puede convertirse en un punto débil para la organización.

El internet de las cosas, conocido como IoT por la expresión inglesa Internet of Things, comprende dispositivos físicos que incorporan capacidades de procesamiento, conectividad y, en muchos casos, recopilación o intercambio de datos. Estos dispositivos interactúan con otros sistemas para apoyar actividades de monitoreo, automatización o control.

Un dispositivo IoT puede incluir sensores, componentes de procesamiento, software interno, interfaces de administración y mecanismos de conectividad. En algunos casos, también depende de una plataforma en la nube o de una aplicación móvil. Esta arquitectura demuestra que el análisis no debe limitarse al equipo físico. La seguridad involucra el dispositivo, la red, las credenciales, los datos y los servicios asociados.

El National Institute of Standards and Technology publicó NISTIR 8259A como una línea base de capacidades de ciberseguridad para dispositivos IoT. El documento plantea que las capacidades técnicas de estos dispositivos deben apoyar controles destinados a proteger tanto los equipos como sus datos, sistemas y ecosistemas relacionados (National Institute of Standards and Technology [NIST], 2020).

Para orientar el diagnóstico de dispositivos conectados, resulta útil revisar las capacidades de ciberseguridad que pueden aportar información sobre configuración, protección, actualización y estado del dispositivo.

- **Capacidades de ciberseguridad en dispositivos IoT**
    - **Identificación del dispositivo**

Permite reconocer si el dispositivo puede identificarse de forma única dentro de la infraestructura.

- **Configuración de seguridad**

Ayuda a determinar si las configuraciones pueden modificarse según las necesidades de protección.

- **Protección de datos**

Orienta la revisión de los mecanismos utilizados para proteger la información que recopila, procesa o transmite el dispositivo.

- **Control de acceso lógico**

Permite analizar qué interfaces se encuentran habilitadas y quién puede acceder a ellas.

- **Actualización de software**

Facilita la revisión sobre la disponibilidad de actualizaciones y soporte del fabricante.

- **Estado de ciberseguridad**

Permite identificar cómo se detectan cambios, comportamientos anómalos o condiciones que requieren revisión.

Estas capacidades permiten formular preguntas útiles durante el diagnóstico: ¿el dispositivo puede identificarse de forma única?, ¿se pueden modificar sus configuraciones de seguridad?, ¿recibe actualizaciones?, ¿qué interfaces se encuentran habilitadas?, ¿cómo se detectan cambios o comportamientos anómalos?

2.2 Vulnerabilidades en dispositivos conectados

Los dispositivos IoT pueden presentar vulnerabilidades relacionadas con credenciales, configuraciones, interfaces, actualizaciones, comunicaciones y tratamiento de datos. Algunas debilidades resultan similares a las observadas en otros

sistemas; sin embargo, su gestión puede ser más compleja debido a la diversidad de fabricantes, capacidades limitadas y ciclos de vida prolongados.

Las vulnerabilidades frecuentes en dispositivos conectados pueden organizarse según la condición observada, el riesgo asociado, la acción preventiva y la evidencia requerida para validar el ajuste.

- **Vulnerabilidades frecuentes en dispositivos IoT**
  - **Credenciales predeterminadas o compartidas**
    - **Riesgo asociado:** acceso no autorizado al dispositivo o a su interfaz administrativa.
    - **Acción preventiva:** asignar credenciales únicas y aplicar procedimientos de gestión de cuentas.
    - **Evidencia para validar:** registro de configuración y prueba de acceso controlada.
  - **Software interno sin actualización**
    - **Riesgo asociado:** exposición a vulnerabilidades divulgadas.
    - **Acción preventiva:** verificar soporte del fabricante y establecer un procedimiento de actualización.
    - **Evidencia para validar:** inventario de versiones y bitácora de cambios.
  - **Interfaces o servicios innecesarios habilitados**
    - **Riesgo asociado:** ampliación de la superficie de ataque.
    - **Acción preventiva:** deshabilitar servicios que no cumplen una función operativa.
    - **Evidencia para validar:** comparación de configuraciones antes y después del ajuste.

- **Dispositivos no inventariados**
  - **Riesgo asociado:** falta de visibilidad y monitoreo.
  - **Acción preventiva:** incorporar el equipo al inventario institucional.
  - **Evidencia para validar:** registro actualizado de activos y responsable asignado.
- **Conectividad sin segmentación**
  - **Riesgo asociado:** posible propagación de una afectación hacia otros sistemas.
  - **Acción preventiva:** separar los dispositivos según su función y nivel de riesgo.
  - **Evidencia para validar:** diagrama de red y validación de reglas de comunicación.
- **Transmisión de datos sin controles adecuados**
  - **Riesgo asociado:** alteración o consulta no autorizada de información.
  - **Acción preventiva:** revisar mecanismos de protección durante el intercambio de datos.
  - **Evidencia para validar:** registro de configuración y prueba funcional autorizada.

Una medida preventiva debe corresponder con la vulnerabilidad identificada. No todas las organizaciones requieren exactamente los mismos controles, pero sí necesitan visibilidad sobre los dispositivos conectados y criterios claros para administrarlos.

2.3 Infraestructuras críticas y procedimientos de mitigación

Algunas infraestructuras sostienen servicios cuya interrupción puede generar impactos amplios sobre la sociedad, la economía o la seguridad. La protección de estos entornos exige una mirada que combine prevención, monitoreo, respuesta y continuidad.

El Decreto 338 de 2022 estableció lineamientos generales para fortalecer en Colombia la gobernanza de la seguridad digital, la identificación de infraestructuras críticas cibernéticas y servicios esenciales, la gestión de riesgos y la respuesta a incidentes. Este enfoque reconoce que la seguridad digital requiere coordinación entre actores y capacidades institucionales (Ministerio de Tecnologías de la Información y las Comunicaciones [MinTIC], 2022).

Una infraestructura crítica comprende activos, sistemas o servicios cuya afectación puede producir consecuencias significativas. Su clasificación depende del contexto nacional y sectorial. Puede involucrar energía, comunicaciones, transporte, salud, servicios financieros, agua, gobierno y otras funciones esenciales.

La criticidad no se determina únicamente por el tamaño de la organización. Un sistema local puede resultar indispensable para una comunidad o un proceso productivo. Un servicio de conectividad, una plataforma hospitalaria o un sistema de control industrial requieren análisis según sus dependencias.

El aprendiz debe comprender que los sistemas físicos y digitales se encuentran relacionados. Un incidente informático puede afectar una operación material. Del mismo modo, una falla física puede interrumpir servicios digitales. Esta relación exige valorar hardware, software, comunicaciones, personas y procedimientos.

La mitigación comienza con la identificación de activos críticos y dependencias. Posteriormente, se analizan vulnerabilidades, amenazas, controles y procedimientos de continuidad. La organización debe establecer responsables, priorizar acciones y conservar documentación.

Entre las medidas pertinentes se encuentran segmentación, control de accesos, actualizaciones, monitoreo, respaldos, procedimientos de respuesta y pruebas de recuperación. La selección depende del entorno. Un sistema crítico requiere controles proporcionales a su función y validaciones periódicas.

La ruta de mitigación permite organizar el tratamiento del riesgo desde la identificación inicial hasta la recuperación del servicio y la mejora posterior.

- **Ruta para mitigar riesgos en infraestructuras críticas**

  A. Identificar

  - **Acción:** reconocer activos, servicios y dependencias.
  - **Propósito:** determinar qué debe protegerse prioritariamente.
  - **Evidencia:** inventario y mapa de dependencias.

  B. Analizar

  - **Acción:** valorar vulnerabilidades, amenazas e impactos.
  - **Propósito:** establecer escenarios de riesgo.
  - **Evidencia:** matriz de riesgos.

  C. Proteger

  - **Acción:** aplicar controles técnicos y organizacionales.
  - **Propósito:** reducir probabilidad e impacto.
  - **Evidencia:** registro de configuraciones y procedimientos.

D. **Monitorear**

- **Acción:** identificar eventos y desviaciones.
- **Propósito:** detectar situaciones que requieren atención.
- **Evidencia:** alertas y bitácoras.

E. **Responder**

- **Acción:** activar procedimientos definidos.
- **Propósito:** contener y gestionar incidentes.
- **Evidencia:** registro de acciones y responsables.

F. **Recuperar**

- **Acción:** restaurar servicios y revisar resultados.
- **Propósito:** fortalecer continuidad y mejora.
- **Evidencia:** pruebas de recuperación e informe final.

Esta ruta permite que la mitigación no se limite a aplicar controles de manera aislada. La identificación, el análisis, la protección, el monitoreo, la respuesta y la recuperación deben documentarse para validar resultados y fortalecer la mejora continua.

3. Ataques, cibercrimen y amenazas dirigidas

La comprensión de los ataques, el cibercrimen y las amenazas dirigidas permite interpretar mejor los hallazgos obtenidos durante el monitoreo, las pruebas de seguridad y la revisión de registros. Este tema aborda la clasificación general de ataques, la evolución del delito digital, los métodos de dispersión y las amenazas que buscan afectar a las personas mediante engaños, suplantación o manipulación.

3.1 Taxonomía y clasificación general de ataques

La ejecución de acciones preventivas y la validación de riesgos requieren comprender cómo pueden desarrollarse los ataques sobre una infraestructura tecnológica. Una vulnerabilidad adquiere mayor significado cuando se analiza en relación con una posible amenaza, el activo expuesto y las consecuencias que podrían producirse. Por esta razón, la clasificación de ataques facilita la interpretación de los hallazgos obtenidos durante el monitoreo, las pruebas de seguridad y la revisión de registros.

Una taxonomía permite ordenar conceptos y reconocer patrones. No debe entenderse como una descripción rígida de todos los incidentes posibles, debido a que un ataque real puede integrar diferentes acciones en una misma secuencia. Un actor puede recopilar información pública, identificar servicios expuestos, intentar obtener credenciales y afectar posteriormente la disponibilidad de un sistema. El análisis profesional exige analizar las relaciones entre estas acciones sin asumir que todos los casos siguen exactamente el mismo recorrido.

Un ataque puede definirse como una acción intencional orientada a comprometer sistemas, redes, aplicaciones, dispositivos o información. Sus efectos pueden incluir acceso indebido, alteración de datos, interrupción de servicios, exposición de información o afectación de la privacidad. La clasificación facilita responder preguntas esenciales: ¿qué buscaba lograr el actor?, ¿qué debilidad intentó aprovechar?, ¿qué activo se encontraba expuesto?, ¿qué evidencia permite sustentar la interpretación?

El análisis debe diferenciar entre una amenaza, un evento y un ataque confirmado. Una amenaza representa la posibilidad de afectación; un evento corresponde a una actividad identificable; y un ataque implica una acción intencional que requiere evidencia suficiente para su clasificación. Diez intentos fallidos de autenticación en pocos minutos constituyen un evento que debe revisarse. La situación puede relacionarse con una prueba legítima, un error de usuario o un intento de acceso no autorizado. La documentación debe conservar esta diferencia y evitar afirmaciones que no puedan demostrarse.

La clasificación general de ataques puede presentarse de acuerdo con su finalidad, la propiedad de seguridad afectada y la evidencia que requiere revisión.

- **Clasificación general de ataques**
  - **Reconocimiento**
    - **Propósito principal:** recopilar información sobre activos, servicios, usuarios o configuraciones.
    - **Ejemplo aplicado:** se identifican consultas o escaneos dirigidos hacia servicios publicados por una organización.

- **Propiedad de seguridad afectada:** puede preparar afectaciones posteriores sobre diferentes propiedades.
- **Evidencia que requiere revisión:** registros de red, inventario de activos, alertas y línea base de comportamiento.

- **Acceso**
  - **Propósito principal:** obtener ingreso no autorizado o utilizar credenciales de manera indebida.
  - **Ejemplo aplicado:** una cuenta administrativa registra intentos repetidos de autenticación o un inicio de sesión inusual.
  - **Propiedad de seguridad afectada:** confidencialidad, integridad y privacidad.
  - **Evidencia que requiere revisión:** registros de acceso, ubicación, horario, perfil del usuario y cambios realizados.
- **Denegación de servicio (DoS)**
  - **Propósito principal:** degradar o impedir el acceso legítimo a sistemas, redes o aplicaciones.
  - **Ejemplo aplicado:** una plataforma virtual deja de responder debido a una carga anómala de solicitudes.
  - **Propiedad de seguridad afectada:** disponibilidad.
  - **Evidencia que requiere revisión:** consumo de recursos, tráfico, registros del servicio y duración de la interrupción.

Esta clasificación aporta una base para interpretar hallazgos, pero no reemplaza la investigación. Un incremento de tráfico puede responder a una actividad legítima; un

acceso fuera de horario puede tener justificación; y un escaneo puede corresponder a una prueba autorizada. El contexto determina la clasificación definitiva.

3.2 Cibercrimen y evolución de las amenazas digitales

La comprensión de los ataques técnicos debe complementarse con una mirada social y organizacional. El cibercrimen no corresponde únicamente a acciones aisladas realizadas por individuos con conocimientos avanzados. También puede involucrar redes, servicios ilícitos, intermediarios y economías digitales que facilitan la especialización de tareas.

INTERPOL señala que el delito digital ha evolucionado desde incidentes aislados hacia una economía clandestina sofisticada que afecta a personas, empresas y organizaciones. Esta transformación exige respuestas coordinadas y capacidad de prevención en diferentes niveles (INTERPOL, 2026).

Europol destaca que el ecosistema del cibercrimen continúa cambiando con rapidez. El informe IOCTA 2026 analiza cómo el cifrado, los servicios `proxy` y la inteligencia artificial amplían determinadas capacidades criminales. También señala la expansión de modelos de `crime-as-a-service`, mediante los cuales algunos actores pueden contratar servicios especializados sin desarrollar directamente todas las capacidades técnicas (Europol, 2026).

El cibercrimen comprende actividades delictivas que utilizan sistemas, redes o servicios digitales como objetivo, medio o escenario. Algunos delitos buscan comprometer infraestructuras; otros utilizan plataformas digitales para ejecutar fraudes, extorsiones o suplantaciones. La tecnología modifica la escala, velocidad y alcance de estas acciones.

El análisis histórico permite reconocer una evolución. Las primeras afectaciones podían concentrarse en acciones experimentales o incidentes limitados. Con el crecimiento de internet, la digitalización de servicios y la expansión de plataformas, aumentó la posibilidad de afectar a usuarios ubicados en diferentes lugares. La incorporación de servicios en la nube, dispositivos conectados y medios digitales amplió tanto las oportunidades legítimas como las superficies de exposición.

El aprendizaje no debe idealizar ni dramatizar la figura del ciberdelincuente. La formación profesional integral requiere una postura crítica. Comprender el fenómeno permite diseñar controles, orientar usuarios y fortalecer la respuesta. El propósito no consiste en replicar prácticas ilícitas, sino en identificar patrones de riesgo.

La clasificación de ciberdelincuentes puede considerar motivaciones, nivel de organización y recursos utilizados. Para facilitar esta lectura, el siguiente recurso organiza los actores y modelos mencionados en el desarrollo.

- **Actores y modelos del cibercrimen**
  - **Actores individuales:** operan con capacidades variables y pueden actuar con diferentes niveles de conocimiento técnico.
  - **Redes organizadas:** distribuyen tareas entre varios participantes y pueden coordinar acciones de mayor alcance.
  - **Intermediarios:** facilitan servicios, datos, herramientas o infraestructura para apoyar actividades ilícitas.
  - **Amenazas internas:** se presentan cuando una persona utiliza indebidamente sus privilegios dentro de una organización.

- **Motivaciones frecuentes:** pueden relacionarse con beneficio económico, interrupción de servicios, notoriedad o acceso a información.
- **Recursos utilizados:** incluyen credenciales, herramientas, datos, infraestructura digital o servicios contratados a terceros.

La clasificación cumple una finalidad defensiva. Permite comprender que las amenazas no siempre provienen de una única persona ni siguen un patrón simple. Una campaña puede integrar suplantación, malware, robo de credenciales y extorsión. La organización debe fortalecer sus controles en diferentes capas.

Los métodos de dispersión son mecanismos mediante los cuales una amenaza alcanza a posibles víctimas. Entre ellos se encuentran mensajes fraudulentos, archivos adjuntos, enlaces engañosos, sitios web comprometidos, componentes desactualizados y credenciales obtenidas de forma indebida.

La dispersión aprovecha tanto vulnerabilidades técnicas como decisiones humanas. Un archivo puede instalar software malicioso si el sistema no aplica controles apropiados. Un enlace puede dirigir hacia una página de suplantación. Un servicio expuesto puede facilitar intentos de acceso. Una dependencia desactualizada puede introducir una debilidad en una aplicación.

3.3. Amenazas cibernéticas dirigidas a personas

Las personas constituyen un objetivo frecuente porque interactúan con sistemas, administran credenciales, reciben mensajes y toman decisiones. Una amenaza puede aprovechar la confianza, la urgencia o la desinformación para inducir una acción

insegura. Por ello, la protección no depende únicamente de herramientas; requiere formación y procedimientos comprensibles.

Las amenazas dirigidas a personas pueden incluir suplantación, fraude, robo de credenciales, exposición de datos y engaños apoyados en ingeniería social. El impacto no se limita al usuario individual. Una cuenta comprometida puede facilitar acceso a recursos organizacionales.

Las amenazas evolucionan con los medios de comunicación. El correo electrónico continúa siendo un canal relevante, pero también se utilizan mensajes de texto, redes sociales, llamadas y aplicaciones de mensajería. La apariencia de legitimidad puede mejorar mediante datos públicos y personalización.

CISA explica que los ataques de phishing utilizan correos o sitios maliciosos para solicitar información personal aparentando provenir de una organización confiable (CISA, 2021b). El concepto se relaciona con la ingeniería social: el atacante intenta influir en la decisión del usuario.

La inteligencia artificial también puede incrementar la capacidad para crear mensajes más convincentes. El FBI advirtió en 2024 sobre el uso de herramientas de inteligencia artificial por parte de ciberdelincuentes para desarrollar campañas sofisticadas de phishing, ingeniería social y clonación de voz o video (Federal Bureau of Investigation [FBI], 2024).

Esta evolución refuerza una idea pedagógica: no basta con buscar errores ortográficos o diseños deficientes. Un mensaje fraudulento puede parecer profesional. La verificación debe considerar el canal, la solicitud, la urgencia, el dominio y el procedimiento institucional.

Para reforzar esta revisión, las señales de análisis pueden presentarse como una ruta breve de verificación antes de responder a un mensaje, abrir un enlace o entregar información.

- **Ruta de verificación ante amenazas dirigidas**
  A. **Revisar el canal:** identifique si el mensaje llegó por un medio institucional, personal o no esperado.
  B. **Analizar la solicitud:** determine si pide datos personales, credenciales, pagos, descargas o acciones urgentes.
  C. **Validar el dominio:** revise si la dirección del sitio o correo corresponde a la entidad legítima.
  D. **Confirmar el procedimiento:** contraste la solicitud con los canales oficiales o procedimientos definidos por la organización.
  E. **Reportar la situación:** comunique el caso mediante los canales adecuados cuando existan indicios de suplantación, fraude o riesgo.

La verificación ayuda a reducir decisiones impulsivas frente a mensajes que aparentan legitimidad. En este tipo de amenazas, la formación del usuario, la claridad de los procedimientos y el reporte oportuno complementan los controles tecnológicos.

4. Internet seguro y clasificación de entornos web

El uso seguro de internet requiere comprender que no todo el contenido digital se encuentra organizado o accesible de la misma manera. La clasificación entre web visible, deep web y dark web facilita orientar prácticas de búsqueda, navegación y gestión de riesgos.

El análisis debe evitar simplificaciones. La deep web no equivale necesariamente a actividades ilícitas. Muchos contenidos legítimos no aparecen en los motores de búsqueda porque requieren autenticación o pertenecen a sistemas internos. La dark web tampoco debe abordarse desde la curiosidad operativa; su estudio tiene una finalidad conceptual y preventiva.

4.1 Clean web, deep web y dark web

La expresión clean web se utiliza en algunos contextos formativos para referirse a la web visible o surface web. Comprende sitios y contenidos que pueden encontrarse mediante motores de búsqueda convencionales. Páginas institucionales, blogs y portales públicos forman parte de este entorno.

La deep web comprende contenidos que no se encuentran indexados por los motores de búsqueda habituales, pero que pueden ser legítimos y accesibles mediante permisos. Entre ellos se encuentran plataformas con autenticación, intranets, bases de datos internas y repositorios restringidos.

La dark web constituye una capa de la deep web que suele requerir software específico y ofrecer mayores niveles de anonimato. La Oficina de Propiedad Intelectual de la Unión Europea explicó en 2024 que la deep web incluye sitios detrás de pagos, autenticación o redes internas, mientras que la dark web corresponde a otra capa que

normalmente necesita herramientas específicas y ofrece navegación más anónima (European Union Intellectual Property Office [EUIPO], 2024).

Europol ha señalado que la dark web puede utilizarse para promocionar mercados y foros relacionados con actividades criminales. Sin embargo, el enfoque educativo no debe fomentar su acceso. El objetivo consiste en reconocer riesgos, comprender conceptos y desarrollar criterios responsables (Europol, 2024).

Para diferenciar estos entornos, la comparación puede presentarse mediante ventanas modales que permitan revisar sus características, ejemplos legítimos y consideraciones de seguridad.

- **Entornos web y criterios de seguridad**
  - **Clean web o surface web**
    - **Característica:** contenido accesible e indexado por motores de búsqueda convencionales.
    - **Ejemplo legítimo:** sitio web institucional o portal informativo.
    - **Consideración de seguridad:** verificar autenticidad, dominio y tratamiento de datos.
  - **Deep web**
    - **Característica:** contenido no indexado que puede requerir autenticación o permisos.
    - **Ejemplo legítimo:** plataforma virtual, correo o repositorio interno.
    - **Consideración de seguridad:** proteger credenciales, permisos y privacidad.

- **Dark web**
  - **Característica:** capa con mayor anonimato que suele requerir herramientas específicas.
  - **Ejemplo legítimo:** su análisis puede ser pertinente para investigación autorizada especializada.
  - **Consideración de seguridad:** no promover navegación exploratoria; aplicar criterios legales, éticos y de seguridad.

Esta clasificación permite comprender que cada entorno requiere criterios diferentes. La navegación segura no depende solo del lugar al que se accede, sino también de la finalidad, la autorización, la fuente consultada y el tratamiento responsable de la información.

4.2 Búsquedas seguras y criterios de consulta

Los motores de búsqueda recopilan, organizan e indexan contenidos públicos. Su uso facilita acceder a información, pero también requiere pensamiento crítico. Un resultado destacado no garantiza autenticidad ni confiabilidad.

El aprendiz debe verificar dominio, fuente, actualidad y finalidad. Antes de ingresar credenciales, conviene acceder directamente al sitio institucional. Los enlaces recibidos mediante mensajes requieren especial atención. También debe distinguir publicidad, contenidos patrocinados y resultados orgánicos cuando la plataforma los presente.

En formación profesional, una búsqueda segura puede orientarse a consultar documentación técnica oficial. Para revisar una vulnerabilidad, deben priorizarse

fuentes institucionales, bases reconocidas y documentación del fabricante. La calidad de la fuente influye en la calidad del diagnóstico.

Los criterios de búsqueda segura ayudan a reducir riesgos durante la consulta de información técnica y la revisión de fuentes digitales.

- **Ruta para realizar búsquedas seguras**
  A. **Verificar el dominio:** revise si la dirección corresponde a una entidad, fabricante o fuente institucional confiable.
  B. **Revisar la fuente:** identifique quién publica la información y si cuenta con respaldo técnico o institucional.
  C. **Confirmar la actualidad:** analice si la información está vigente y corresponde al contexto de la consulta.
  D. **Reconocer la finalidad:** determine si el contenido informa, promociona, solicita datos o intenta dirigir una acción.
  E. **Priorizar fuentes oficiales:** consulte documentación técnica, bases reconocidas, repositorios normativos o fuentes académicas.

Esta ruta fortalece la consulta responsable de información y evita que el diagnóstico se base en resultados poco confiables, enlaces riesgosos o fuentes sin respaldo técnico.

4.3 Buscadores especializados y criterios de seguridad

Los buscadores especializados permiten localizar información en ámbitos concretos, como documentación académica, normativa o repositorios técnicos. Su utilización puede mejorar la precisión de una consulta. Sin embargo, deben aplicarse criterios de seguridad y pertinencia.

El término “buscadores especiales” no debe interpretarse como una invitación a explorar entornos de riesgo. La formación se concentra en herramientas legítimas para consultar información verificable: repositorios normativos, bases de vulnerabilidades, documentación oficial y fuentes académicas.

Una pregunta orientadora resulta útil: ¿la fuente consultada permite verificar la información sin exponer al usuario ni promover prácticas indebidas? La respuesta debe guiar el proceso. Un diagnóstico responsable utiliza fuentes confiables, documenta la consulta y protege los datos.

5. Monitoreo, mitigación y validación de riesgos

El monitoreo, la mitigación y la validación de riesgos permiten pasar de la identificación de vulnerabilidades a la toma de decisiones sustentada en evidencias. Este tema aborda métodos de seguimiento, herramientas tecnológicas de seguridad, acciones de mitigación y procedimientos para comprobar si los controles aplicados reducen la exposición sin afectar el funcionamiento legítimo de los servicios.

5.1 Métodos y técnicas de monitoreo

El monitoreo de red permite analizar el comportamiento de los activos tecnológicos, reconocer desviaciones frente a la operación esperada y recopilar evidencias para la toma de decisiones. Su finalidad no consiste en vigilar indiscriminadamente cada interacción ni en almacenar datos sin criterios definidos. Un monitoreo responsable responde a objetivos concretos de seguridad, respeta la privacidad y facilita la detección oportuna de eventos que podrían afectar los servicios.

La infraestructura tecnológica produce información de manera continua. Los servidores registran accesos, errores y cambios; las aplicaciones conservan eventos de autenticación; los dispositivos conectados generan comunicaciones; y los servicios en la nube proporcionan métricas, alertas y registros de actividad. El valor de estos datos depende de la capacidad organizacional para analizarlos y relacionarlos con activos, riesgos y necesidades reales.

El monitoreo comienza con la identificación de los activos que requieren seguimiento. Una organización debe reconocer qué equipos, aplicaciones, servicios, cuentas y dispositivos forman parte de su infraestructura. Después, necesita definir qué

comportamiento espera de ellos y qué cambios podrían representar una desviación relevante.

Una línea base describe la condición habitual o esperada de un activo. Puede incluir aplicaciones instaladas, servicios habilitados, horarios de uso, conexiones permitidas y niveles aproximados de consumo de recursos. La comparación con esta referencia ayuda a detectar comportamientos anómalos.

Considérese una plataforma virtual utilizada principalmente durante jornadas académicas. Un aumento de accesos durante la entrega de actividades puede ser legítimo. Sin embargo, múltiples intentos fallidos sobre una cuenta administrativa en un horario inusual requieren revisión. La diferencia no se determina únicamente mediante una alerta automática: exige comprender el contexto.

Los métodos de monitoreo pueden incluir revisión de registros, análisis de tráfico, análisis de métricas, seguimiento de configuraciones y correlación de eventos. Cada técnica aporta una perspectiva distinta. Los registros permiten reconstruir acciones; las métricas muestran cambios en disponibilidad o consumo; y la revisión de configuraciones identifica modificaciones que podrían ampliar la exposición.

El monitoreo continuo no significa revisar manualmente cada evento en todo momento. Significa establecer una frecuencia suficiente para tomar decisiones basadas en riesgos. Una pequeña organización puede comenzar con procedimientos sencillos: conservar registros esenciales, revisar alertas prioritarias y asignar responsables. La calidad del proceso depende más de su coherencia y continuidad que de la cantidad de herramientas instaladas.

5.2 Herramientas tecnológicas de seguridad

Las herramientas apoyan la prevención, detección, análisis y respuesta. Su selección debe corresponder con el tipo de activo, el riesgo identificado y la capacidad de la organización. Una solución avanzada puede resultar poco útil si no existe personal encargado de revisar sus alertas. Una herramienta básica puede aportar valor cuando se integra a un procedimiento claro.

Las herramientas de seguridad pueden organizarse según su finalidad, aplicación posible y criterio de selección. Para facilitar su consulta, la siguiente información se presenta como un recurso interactivo.

- **Herramientas de seguridad y criterios de selección**
  - **Inventario automatizado**
    - **Finalidad principal:** reconocer activos de hardware y software.
    - **Aplicación posible:** identificar equipos conectados y aplicaciones instaladas.
    - **Criterio de selección:** debe facilitar actualización, clasificación y asignación de responsables.
  - **Escáner de vulnerabilidades**
    - **Finalidad principal:** detectar condiciones técnicas que requieren validación.
    - **Aplicación posible:** revisar versiones, servicios y configuraciones en entornos autorizados.
    - **Criterio de selección:** debe utilizarse con alcance definido y contrastar los hallazgos.

- **Antimalware**
  - **Finalidad principal:** prevenir, detectar o contener software perjudicial.
  - **Aplicación posible:** proteger equipos de usuario y servidores.
  - **Criterio de selección:** requiere actualización, monitoreo y revisión de alertas.
- **Firewall**
  - **Finalidad principal:** controlar comunicaciones según reglas definidas.
  - **Aplicación posible:** limitar accesos y reducir exposición innecesaria.
  - **Criterio de selección:** las reglas deben documentarse y validarse periódicamente.
- **IDS o IPS**
  - **Finalidad principal:** detectar o bloquear patrones asociados con actividades anómalas.
  - **Aplicación posible:** identificar eventos de red o proteger servicios relevantes.
  - **Criterio de selección:** debe ajustarse para equilibrar protección y operación legítima.
- **EDR**
  - **Finalidad principal:** analizar comportamientos y facilitar respuesta en equipos finales.
  - **Aplicación posible:** analizar actividad inusual en computadores y servidores.
  - **Criterio de selección:** requiere responsables para investigar alertas y documentar acciones.

- **SIEM**
  - **Finalidad principal:** centralizar y correlacionar registros.
  - **Aplicación posible:** analizar accesos, alertas y eventos provenientes de múltiples fuentes.
  - **Criterio de selección:** debe priorizar información útil y proteger los registros.
- **SOAR**
  - **Finalidad principal:** automatizar y coordinar determinados flujos de respuesta.
  - **Aplicación posible:** gestionar alertas repetitivas o procedimientos predefinidos.
  - **Criterio de selección:** la automatización debe probarse en condiciones controladas.
- **Copias de respaldo**
  - **Finalidad principal:** facilitar recuperación de información y servicios.
  - **Aplicación posible:** restaurar datos después de una afectación.
  - **Criterio de selección:** deben realizarse pruebas periódicas de recuperación.

La selección de herramientas no debe depender únicamente de la cantidad de funciones disponibles. Su valor se relaciona con la capacidad de integrarlas a procedimientos claros, asignar responsables, revisar alertas y documentar resultados.

5.3 Mitigación de riesgos y verificación de resultados

La mitigación busca reducir la probabilidad de materialización o disminuir el impacto. Puede incluir controles preventivos, detectivos y correctivos. La selección

depende del riesgo. Una vulnerabilidad de software puede requerir actualización; una configuración insegura puede necesitar ajustes; un acceso excesivo puede resolverse mediante privilegio mínimo; y una exposición de datos puede exigir restricciones adicionales.

El tratamiento debe documentarse. Antes de modificar un sistema se registra el estado inicial. Después se aplica la acción en condiciones controladas. Finalmente, se valida que el cambio reduzca la exposición sin impedir el funcionamiento legítimo.

La validación puede incluir una nueva revisión de configuración, una prueba autorizada, el análisis de registros o una comparación antes y después. Cuando se corrige una debilidad en una aplicación, conviene realizar una prueba de regresión de seguridad para comprobar que la modificación no introdujo efectos no previstos.

NIST SP 800-61 Rev. 3 integra la respuesta a incidentes con la gestión de riesgos de ciberseguridad. El documento destaca la preparación, la reducción del número e impacto de incidentes y la mejora de las actividades de detección, respuesta y recuperación (NIST, 2025). Esta visión resulta aplicable a la mitigación: el aprendizaje no concluye cuando se ejecuta una acción; se completa cuando el resultado se verifica y se incorpora a la mejora continua.

La mitigación y validación de riesgos pueden organizarse como una ruta que inicia con el análisis del riesgo y finaliza con la incorporación de aprendizajes al proceso.

- **Ruta para mitigar y validar riesgos**

  A. Analizar

  - **Acción:** revisar activo, vulnerabilidad, amenaza e impacto.
  - **Pregunta orientadora:** ¿qué riesgo requiere tratamiento prioritario?
  - **Evidencia:** matriz de riesgos y hallazgos.

B. **Seleccionar**
   - **Acción:** elegir un control proporcional.
   - **Pregunta orientadora:** ¿qué medida reduce el riesgo sin afectar la operación legítima?
   - **Evidencia:** justificación técnica del control.

C. **Implementar**
   - **Acción:** aplicar el ajuste en condiciones autorizadas.
   - **Pregunta orientadora:** ¿qué cambió y quién realizó la modificación?
   - **Evidencia:** registro de cambio.

D. **Validar**
   - **Acción:** comprobar efectividad y funcionamiento.
   - **Pregunta orientadora:** ¿el control redujo la exposición y mantiene el servicio?
   - **Evidencia:** pruebas posteriores y registros.

E. **Documentar**
   - **Acción:** consolidar resultados y recomendaciones.
   - **Pregunta orientadora:** ¿qué evidencia sustenta la conclusión?
   - **Evidencia:** informe técnico actualizado.

F. **Mejorar**
   - **Acción:** incorporar aprendizajes al proceso.
   - **Pregunta orientadora:** ¿qué debe revisarse periódicamente?
   - **Evidencia:** plan de seguimiento.

Esta ruta permite que la mitigación no se limite a ejecutar una acción técnica. La validación, la documentación y la mejora continua son necesarias para comprobar resultados, conservar trazabilidad y fortalecer futuras decisiones de seguridad.

Para complementar el estudio de la mitigación de riesgos y la verificación de resultados, acceda al pódcast Validar antes de cerrar: cómo comprobar una mitigación. En este recurso se explica por qué una acción de seguridad no debe considerarse finalizada hasta comprobar su efectividad, conservar evidencias y documentar los resultados. Esta información le permitirá fortalecer la toma de decisiones, validar controles aplicados y comprender la importancia de cerrar los hallazgos con criterios técnicos, éticos y verificables.

Transcripción del pódcast: validar antes de cerrar: cómo comprobar una mitigación
Cortina Musical. **Personaje 1 (Mujer):** ¡Bienvenidos a este espacio formativo! Hoy hablaremos sobre un paso que, en muchas ocasiones, se pasa por alto en ciberseguridad: “Validar antes de cerrar: cómo comprobar una mitigación”. **Personaje 2 (Hombre):** así es; en seguridad de la información, mitigar un riesgo implica mucho más que instalar una herramienta o modificar una configuración. También es necesario validar los resultados y documentar las evidencias. Solo así es posible confirmar que el control implementado protege la información sin afectar el funcionamiento normal de los sistemas. ¡Bienvenidos! Cortina Musical. **Personaje 1 (Mujer):** pensemos en una situación sencilla. En una plataforma virtual se detecta que una cuenta administrativa tiene permisos superiores a los

necesarios. El equipo técnico ajusta esos permisos y da por terminado el trabajo. Pero surge una pregunta importante: ¿ese cambio es suficiente para afirmar que el riesgo quedó mitigado?

Personaje 2 (Hombre): la respuesta es no. Una mitigación efectiva comienza con la identificación del riesgo, continúa con la selección de un control proporcional y su implementación en condiciones autorizadas. Sin embargo, el proceso solo se completa cuando se verifica que ese control realmente reduce la exposición al riesgo y mantiene el funcionamiento legítimo del servicio.

Personaje 1 (Mujer): por eso, una acción preventiva debe cumplir tres condiciones fundamentales. Primero, responder al riesgo identificado y no aplicarse de forma improvisada. Segundo, validarse mediante evidencias, como registros, pruebas posteriores, revisión de configuraciones o comparaciones entre el antes y el después. Y tercero, documentarse para conservar la trazabilidad y facilitar futuras decisiones.

Personaje 2 (Hombre): veamos un ejemplo. En una institución educativa se detectan múltiples intentos fallidos de acceso a una cuenta administrativa fuera del horario habitual. El primer paso consiste en analizar el activo comprometido, la vulnerabilidad, la amenaza y el posible impacto sobre la organización.

Personaje 1 (Mujer): con esa información se selecciona un control adecuado. Dependiendo del caso, puede ser revisar los permisos de la cuenta, activar la autenticación multifactor o fortalecer el monitoreo mediante herramientas como un SIEM, un firewall o un sistema antimalware. Lo importante es que la medida sea proporcional al riesgo identificado.

Personaje 2 (Hombre): después de implementar el control llega la etapa más importante: la validación. Es necesario comprobar si disminuyeron los intentos de acceso no autorizados, si la cuenta continúa funcionando correctamente para los usuarios autorizados y si los registros respaldan la efectividad de la medida adoptada.

Personaje 1 (Mujer): cuando esta metodología se aplica correctamente, la organización reduce su exposición a los riesgos, conserva evidencia técnica y evita decisiones basadas en suposiciones.

Personaje 2 (Hombre): en cambio, si la validación se omite, puede generarse una falsa sensación de seguridad, manteniendo vulnerabilidades que aún no han sido corregidas o afectando la operación normal del servicio.

Personaje 1 (Mujer): solo cuando se verifica el resultado y se documenta la evidencia puede afirmarse que el proceso de mitigación se completó de manera responsable.

Personaje 2 (Hombre): porque en ciberseguridad no basta con implementar controles…

Personaje 1 (Mujer): mitigar, validar y documentar forman una misma ruta de protección. Aplicar esta metodología fortalece la seguridad de la información y contribuye a una toma de decisiones ética, responsable y basada en evidencias.

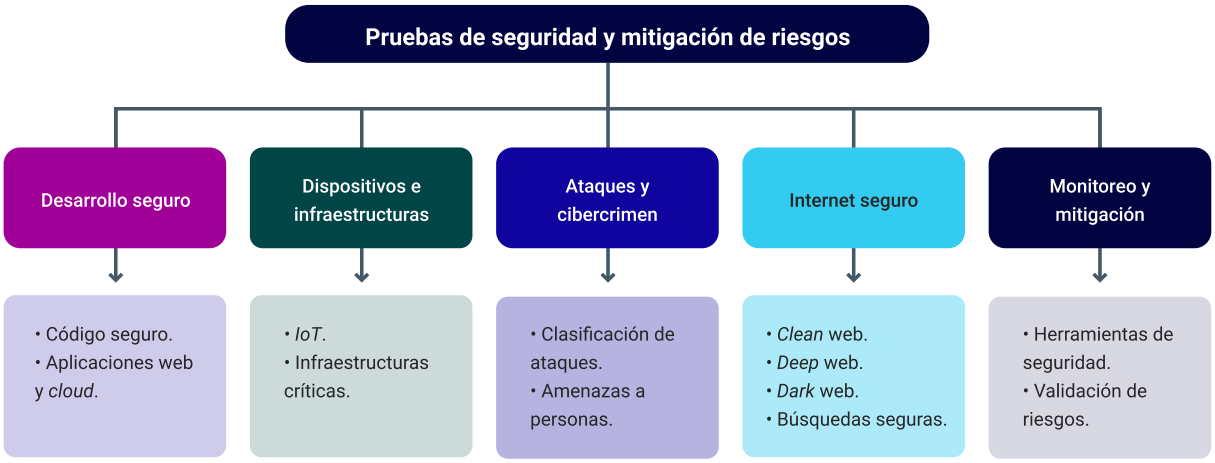
Personaje 2 (Hombre): gracias por acompañarnos, ¡nos escuchamos en un próximo episodio!

Cortina Musical.

Síntesis

El componente formativo Pruebas de seguridad y mitigación de riesgos desarrolla una visión aplicada de la ciberseguridad orientada a la prevención, el monitoreo y la validación de resultados. La protección de los activos requiere integrar código seguro, control de accesos, gestión de vulnerabilidades, seguridad en servicios cloud, protección de dispositivos IoT, análisis de ataques, clasificación de entornos web, revisión de registros y documentación de hallazgos. Las herramientas tecnológicas apoyan la identificación y respuesta, pero su efectividad depende de procedimientos definidos, responsables asignados y evidencias verificables.

La mitigación de riesgos es un proceso continuo que implica identificar activos, analizar vulnerabilidades y amenazas, seleccionar controles, implementar acciones, validar su efectividad y documentar resultados. El aprendiz fortalece su capacidad para interpretar ataques, comprender la evolución del cibercrimen, reconocer amenazas dirigidas a personas, aplicar criterios de navegación segura y proponer medidas para proteger información, servicios e infraestructuras críticas desde una actuación ética y responsable.



Glosario

Autenticación multifactor: mecanismo que utiliza más de una evidencia para verificar la identidad de un usuario y reducir el riesgo de acceso indebido.

Código seguro: software desarrollado mediante prácticas que reducen vulnerabilidades y protegen datos, permisos, sesiones y operaciones.

Control de seguridad: medida técnica, organizacional o formativa destinada a prevenir, detectar, corregir o reducir un riesgo.

Dark web: capa de internet que suele requerir herramientas específicas y ofrece mayor anonimato. su estudio debe mantener un propósito conceptual, legal y preventivo.

Deep web: contenido no indexado por motores de búsqueda convencionales, como plataformas autenticadas, repositorios privados o sistemas internos.

Denegación de servicio (DoS): ataque orientado a degradar o impedir el acceso legítimo a una aplicación, red o servicio tecnológico.

EDR: solución de detección y respuesta orientada a analizar comportamientos y facilitar la revisión en equipos finales.

Firewall: control que permite o restringe comunicaciones según reglas definidas y documentadas.

IDS: sistema que detecta patrones o eventos de red que requieren análisis y genera alertas.

Incidente de seguridad: situación que afecta o pone en riesgo sistemas, información, servicios o usuarios y requiere tratamiento documentado.

Internet de las cosas (IoT): ecosistema de dispositivos físicos conectados que recopilan, procesan o intercambian datos.

Referencias bibliográficas

Center for Internet Security. (2024). CIS Critical Security Controls version 8.1.

Cybersecurity and Infrastructure Security Agency. (2021). Avoiding social engineering and phishing attacks.

Cybersecurity and Infrastructure Security Agency. (2022). Cloud security technical reference architecture.

Cybersecurity and Infrastructure Security Agency. (2023). Shifting the balance of cybersecurity risk: Principles and approaches for secure by design software.

Cybersecurity and Infrastructure Security Agency. (2025). Implementing SIEM and SOAR platforms: Practitioner guidance.

Departamento Nacional de Planeación. (2020). Documento CONPES 3995: Política nacional de confianza y seguridad digital.

European Union Agency for Cybersecurity. (2024). ENISA threat landscape 2024. Publications Office of the European Union.

European Union Intellectual Property Office. (2024). Uncovering the ecosystem of intellectual property crime: A focus on enablers and impact.

Europol. (2024). Internet Organised Crime Threat Assessment (IOCTA) 2024.

Europol. (2026). Internet Organised Crime Threat Assessment (IOCTA) 2026.

Federal Bureau of Investigation. (2024). FBI warns of increasing threat of cyber criminals utilizing artificial intelligence.

INTERPOL. (s. f.). Cybercrime.

Ministerio de Tecnologías de la Información y las Comunicaciones. (2022). Decreto 338 de 2022: Lineamientos generales para fortalecer la gobernanza de la seguridad digital.

National Institute of Standards and Technology. (2020). IoT device cybersecurity capability core baseline (NISTIR 8259A). U.S. Department of Commerce.

National Institute of Standards and Technology. (2022). Secure Software Development Framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities (NIST Special Publication 800-218). U.S. Department of Commerce.

National Institute of Standards and Technology. (2025). Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST Special Publication 800-61, Revision 3). U.S. Department of Commerce.

OWASP Foundation. (2025a). OWASP Application Security Verification Standard 5.0.

OWASP Foundation. (2025b). OWASP Top 10: The ten most critical web application security risks.

Créditos

Nombre	Cargo	Centro de Formación y Regional
Claudia Johanna Gómez Pérez	Profesional G06. Responsable Ecosistema Virtual de Recursos Educativos Digitales	Centro Agroturístico - Regional Santander
Edison Eduardo Mantilla Cuadros	Responsable de línea de producción	Centro Agroturístico - Regional Santander
Carlos Andrés Bonza Reyes	Experto temático TIC	Centro Agroturístico - Regional Santander
Angélica Varón Quintero	Evaluadora instruccional	Centro Agroturístico - Regional Santander
Marcos Yamid Rubiano Avellaneda	Diseñador de contenidos	Centro Agroturístico - Regional Santander
Lizeth Karina Manchego Suarez	Desarrolladora full stack	Centro Agroturístico - Regional Santander
Maria Alejandra Vera Briceño	Animadora y productora audiovisual	Centro Agroturístico - Regional Santander
Sandra Liliana Cristancho Cruz	Validadora y vinculadora de recursos educativos digitales	Centro Agroturístico - Regional Santander
Laura Paola Gelvez Manosalva	Evaluadora de contenidos inclusivos y accesibles	Centro Agroturístico - Regional Santander